ZERO-TRUST-SUPPLY-CHAIN-N2SF

제로 트러스트·공급망 보안·N2SF

연관 기출 · 131-2-4, 135-4-6, 136-4-4, 137-3-6

한눈에 이해

내부망·기존 계정·납품업체라는 이유만으로 접근을 허용하지 않고 자원별 정책과 관측 증거로 판단합니다.

정의와 핵심 원리

제로트러스트는위치나자산소유만으로암묵적신뢰를 주지않고각접근의 인증·인가·상태를 평가하는보안원칙입니다. 공급망보안은개발·빌드·의존성·배포·운영의 신뢰를 관리하며 N2SF는 국가·공공기관의 정보중요도와위협 기반망보안체계를지향합니다.

• NIST800-207의정책엔진은접근 결정, 정책 관리자는 통신 경로 설정·해제, PEP는 연결을 허용·감시·종료합니다. 모든 통신 보호·세션별최소 권한·동적정책·자산상태관측과지속적인증거 수집이 핵심이며 인증 반복만으로정의하지 않습니다.

• 공급망은소스 보호·동료검토·의존성고정·취약점/라이선스 분석·격리 빌드·서명·provenance·SBOM·배포 검증·운영 감시를 연결합니다. 빌드작업의 NHI·토큰도 짧은수명·최소 권한으로 보호하고 외부공급자의 접근을 서비스별로 제한합니다.

• N2SF는 정보·서비스식별과C/S/O분류등을 통해 업무 환경에 맞는보안대책을정하는맥락으로설명합니다. 2025년초안과2025.9정식1.0·후속지침은 구분해야합니다. CISA성숙도2.0의단계·기둥·횡단기능과 N2SF세부통제는 원문 미열람상태에 서 정확한필수목록을 확정하지 않습니다.

구조·비교·판단

구분	핵심 원리	적용·한계
경계보안	망위치중심기본 정책	경계 통제는 여전히활용가 능
제로트러스트	자원·신원·상태·세션	점진이행·관측필요
공급망/N2SF	생애주기 신뢰/공공위험 기반	서명·분류만 으로완료아님

적용 예제

외부 유지보수업체 접근

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 협력사계정으로 내부전체 VPN 접근하던환경

1. 자산·서비스·신원·데이터 흐름을 식별합니다.
2. 유지보수대상·시간·승인·단말 상태에 맞춘접근 정책을 둡니다.
3. 연결중행위와 위험 상태를 관측하고 필요시세션을 끊습니다.
4. 서명된배포물·작업 기록과 계약 종료 권한 회수를 검증합니다.

결과·해석: 망경계하나의신뢰를 업무 자원별검증과 수명 관리로 세분합니다.

전제·주의: CISA2.0은403, N2SF공식 원문은 미열람입니다.일반 ZT설계를 해당제도세부요건충족으로표시하지 않습니다.

답안 골격과 혼동 방지

원칙 → PE/PA/PEP도 식 → 경계비교 → 공급망적용 → N2SF검증 상태

- ZT도 입을VPN제거제품하나로축소하지 않습니다.
- 물리망분리와 ZT를 항상 택일이라고설명하지 않습니다.

내용을 가리고 회상

1. 세션별최소 권한은 무엇입니까?
2. 서명된악성코드도 가능한 이유는무엇입니까?
3. N2SF정보등급과사용자 인가를 어떻게연결합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-207: Zero Trust Architecture - Scott Rose et al. / NIST; 2020-08; 확인 2026-11-05.
- Workload identities overview - Microsoft; 상시 문서; 확인 2026-11-05.